BIS406

Information Systems Audit and Control

ข้อสอบปลายภาค: กรณีศึกษา

ธนาคารเกษมทรัพย์ จำกัด (มหาชน)

Kasem Sap Bank Public Company Limited

คำชี้แจงสำคัญ

ข้อสอบนี้มีทั้งหมด 6 ข้อ ให้นักศึกษาเลือกตอบเพียง 5 ข้อ คำตอบที่ดีต้องอ้างอิงข้อเท็จจริงเฉพาะจากกรณีศึกษาของธนาคารเกษมทรัพย์ ไม่ใช่คำตอบในเชิงทฤษฎีทั่วไป แต่ละข้อมีคำตอบที่เหมาะสมที่สุดซึ่งอาจแตกต่างจากคำตอบที่ถูกต้องตามหลักการ ขึ้นอยู่กับบริบทและข้อจำกัดของบริษัท

ชื่อ-สกุล:	**รหัสนักศึกษา:** .....

กรุณาอ่านกรณีศึกษาให้ครบก่อนตอบคำถาม

ส่วนที่ 1 — ภาพรวมองค์กรและบริบทธุรกิจ

1.1 ประวัติและภาพรวมบริษัท

ธนาคารเกษมทรัพย์ จำกัด (มหาชน) หรือ KSB ก่อตั้งขึ้นในปี พ.ศ. 2521 จากการควบรวมกิจการระหว่างสหกรณ์เครดิตภาคใต้กับกองทุนพัฒนาชุมชนภาคกลาง ด้วยทุนจดทะเบียนเริ่มต้น 500 ล้านบาท ธนาคารเติบโตอย่างต่อเนื่องตลอดหลายทศวรรษ จนปัจจุบันมีสาขาทั่วประเทศ 187 สาขา พนักงานกว่า 6,200 คน และสินทรัพย์รวมประมาณ 3.2 แสนล้านบาท (ณ สิ้นปี 2566)

ธนาคารเกษมทรัพย์ถือหุ้นอยู่ในตลาดหลักทรัพย์แห่งประเทศไทย (SET) ภายใต้รหัส KSB และได้ขยายธุรกิจเพิ่มเติมด้วยการจัดตั้ง บริษัทเกษมทรัพย์ เวลธ์ แมเนจเมนต์ จำกัด (KSB Wealth) ซึ่งให้บริการนายหน้าซื้อขายหลักทรัพย์และจัดการกองทุน ทำให้อยู่ภายใต้การกำกับดูแลทั้งของธนาคารแห่งประเทศไทย (ธปท.) และสำนักงานคณะกรรมการกำกับหลักทรัพย์และตลาดหลักทรัพย์ (ก.ล.ต.) พร้อมกัน

1.2 ผลิตภัณฑ์และบริการ

กลุ่มผลิตภัณฑ์	รายได้คิดเป็น % ของรายได้รวม	ช่องทางหลัก
สินเชื่อรายย่อยและ SME	38%	สาขา, Mobile Banking (KSB Go)
เงินฝากและผลิตภัณฑ์ตลาดเงิน	26%	Internet Banking, ATM
สินเชื่อธุรกิจขนาดใหญ่	22%	Relationship Manager
บริหารความมั่งคั่งและหลักทรัพย์ (KSB Wealth)	14%	แอปพลิเคชัน KSB Wealth, โทรศัพท์

1.3 โครงสร้างการกำกับดูแลและกฎระเบียบที่เกี่ยวข้อง

ธนาคารเกษมทรัพย์ดำเนินงานภายใต้กรอบกฎระเบียบที่สำคัญหลายชุดพร้อมกัน ดังนี้

ธนาคารแห่งประเทศไทย (ธปท.): ประกาศ ธปท. ที่ สนส. 3/2563 ว่าด้วยการบริหารความเสี่ยงด้านเทคโนโลยีสารสนเทศของสถาบันการเงิน รวมถึงแนวทาง IT Risk Management Implementation Guideline และข้อกำหนด BCBS 239 ว่าด้วยความถูกต้องของข้อมูลรายงานความเสี่ยง

สำนักงาน ก.ล.ต.: ข้อกำหนดการรักษาความมั่นคงปลอดภัยด้าน Cybersecurity สำหรับผู้ประกอบธุรกิจหลักทรัพย์ (สำหรับ KSB Wealth)

พ.ร.บ. คุ้มครองข้อมูลส่วนบุคคล พ.ศ. 2562 (PDPA): ธนาคารอยู่ระหว่างการปรับปรุงระบบเพื่อให้สอดคล้องกับข้อกำหนด บางส่วนที่ยังดำเนินการไม่แล้วเสร็จ

มาตรฐาน PCI-DSS v4.0: เนื่องจากธนาคารประมวลผลธุรกรรมบัตรเครดิตและบัตรเดบิตด้วยตนเอง

1.4 โครงสร้างองค์กรด้าน IT

ฝ่ายเทคโนโลยีสารสนเทศของธนาคารเกษมทรัพย์มีโครงสร้างดังนี้

ตำแหน่ง / หน่วยงาน	รายงานต่อ	หมายเหตุ
Chief Information Officer (CIO) — นายประเสริฐ วงศ์มณี	Chief Financial Officer (CFO)	รายงานต่อ CFO ไม่ใช่ CEO โดยตรง
Head of IT Infrastructure — นางสาวสุภาพร ทองดี	CIO	ดูแล on-premise และ cloud
Head of Application Development — นายอานนท์ ศิริพันธ์	CIO	ทีม 28 คน พัฒนาและดูแล core systems
Head of IT Security — นางสาวณิชาภา วิชัยดิษฐ	CIO	IT Security ไม่ได้รายงานต่อ CISO หรือ Board โดยตรง
IT Operations Team (12 คน)	Head of Infrastructure	ดูแล NOC, Backup, Monitoring
Change Advisory Board (CAB)	CIO	ประชุมทุก 2 สัปดาห์ ประกอบด้วย Dev, Ops, Security, Business

สิ่งที่ฝ่ายบริหารกังวลใจ (Management Concerns)

ประธานกรรมการบริหาร (CEO) ได้แสดงความกังวลต่อคณะกรรมการในการประชุมไตรมาส 3/2566 ใน 3 ประเด็นหลัก ได้แก่

- (1) ค่าใช้จ่ายด้าน IT ที่เพิ่มขึ้นสูงถึง 18% เมื่อเทียบกับปีก่อน โดยไม่มีผลประโยชน์ทางธุรกิจที่ชัดเจน
- (2) การที่ระบบ Mobile Banking หยุดทำงานถึง 3 ครั้งในรอบ 12 เดือนที่ผ่านมา ซึ่งส่งผลให้ลูกค้าร้องเรียนต่อ ธปท. จำนวน 47 ราย และ
- (3) ผลการตรวจสอบจากผู้สอบบัญชีภายนอก (External Auditor) ที่พบข้อบกพร่องด้าน IT General Controls ซึ่งยังไม่ได้รับการแก้ไขมาตั้งแต่รอบการตรวจสอบปี 2564

ส่วนที่ 2 — สถาปัตยกรรม IT และระบบงาน

2.1 ภาพรวมสถาปัตยกรรม IT แบบ Hybrid

ธนาคารเกษมทรัพย์ใช้สถาปัตยกรรม IT แบบ Hybrid โดยแบ่งชั้นระบบออกเป็น 3 ส่วนหลักดังนี้

ชั้นระบบ	ที่ตั้ง	ระบบสำคัญ	สถานะ
Core Banking & Transaction Processing	On-Premise Data Center (IDC Bangkok)	TEMENOS T24 R20, Swift Gateway, BAHTNET Interface	Production
Customer-Facing Digital Channels	AWS (ap-southeast-1, Singapore)	KSB Go Mobile App, Internet Banking Portal, API Gateway (Kong)	Production
Support & Collaboration	Microsoft Azure (Thailand Region)	Microsoft 365, Teams, SharePoint, Power BI	Production
Development & Testing	On-Premise (แยก VLAN)	Dev Server, UAT Environment, Version Control (GitLab)	Development
Disaster Recovery Site	Co-location ศูนย์ข้อมูล จ. ชลบุรี	Replication ของ Core Banking เท่านั้น	Standby — ยังไม่ผ่าน Full DR Test

2.2 รายละเอียดระบบงานหลัก (Application Landscape)

ระบบงาน	Vendor / Platform	ผู้รับผิดชอบ	ข้อมูลสำคัญ	ความเสี่ยงที่ระบุ
TEMENOS T24 Core Banking	Temenos (ผ่าน Local Reseller)	IT Application Team	ลูกค้า 1.4 ล้านราย, ธุรกรรม ~240,000 รายการ/วัน	Version เก่ากว่า Latest 3 Major Release
KSB Go Mobile Banking	พัฒนาภายใน (Flutter)	IT Application Team	MAU ~680,000 ราย	Dependency ต่อ AWS Lambda หากล่มจะกระทบทั้งระบบ
Core Lending System (CLS)	Oracle FLEXCUBE	IT Application Team + Vendor Support	สินเชื่อค้างชำระ >90 วัน ถูก Flag อัตโนมัติ	Interface กับ T24 บางส่วนยังเป็น Manual Batch
KSB Wealth Trading Platform	FIS Profile (Licensed)	KSB Wealth IT (แยกทีม)	ซื้อขายหลักทรัพย์ผ่าน SET Link	SLA การ Patch ล่าช้า เนื่องจากต้องรอ Vendor แพตช์ก่อน
Human Resources & Payroll	SAP SuccessFactors (Cloud)	HR + IT	ข้อมูลพนักงาน 6,200 คน	Account ของพนักงานที่ลาออกบางรายยังไม่ถูก Deactivate
Regulatory Reporting System	พัฒนาภายใน (.NET)	IT Application Team	ส่งรายงานต่อ ธปท. และ ก.ล.ต.	ยังไม่ผ่านการ Review Source Code อย่างเป็นทางการ

2.3 สรุปสถานะ IT General Controls

ด้าน ITGC	ประเมินโดย	สรุปสถานะ	ระดับความเสี่ยง
Access Control & Identity Management	IT Security Team (Self-Assessment)	มีนโยบาย User Access Management แต่กระบวนการ Recertification ยังทำไม่ครบตามรอบที่กำหนด พบว่า Production Database ของ T24 มี Shared Admin Account ที่ใช้ร่วมกัน 4 คน	สูง
Change Management & SDLC	CAB ประเมินตนเอง	มี Change Request (CR) Process อย่างเป็นทางการ แต่ในทางปฏิบัติพบว่า Emergency Change ถูกใช้บ่อยผิดปกติ (34% ของ Change ทั้งหมดในปี 2566 ถูก Classify เป็น Emergency) และ Developer บางรายมีสิทธิ์ Deploy ตรงสู่ Production Environment โดยไม่ผ่าน Approval	สูงมาก
IT Operations & Backup	IT Operations Team	มีการ Backup ข้อมูลประจำวัน แต่ Restoration Test ครั้งล่าสุดเกิดขึ้นเมื่อเดือนมีนาคม 2564 และยังไม่ดำเนินการอีกครั้ง ทีม Ops อ้างว่าไม่มีเวลาเพราะต้องดูแล Production System เต็มเวลา	สูง
Business Continuity & DR	ไม่มีการประเมินอิสระ	DR Site ที่ชลบุรีถูก Provision ไว้ตั้งแต่ปี 2564 แต่ยังไม่เคยทำ Full Failover Test ทีม IT อ้างว่า Core Banking เคยทดสอบ Partial Replication แต่ไม่มีเอกสารบันทึกผล	สูงมาก
Patch Management	IT Security Team	มีกระบวนการ Patch Management แต่ Critical Patch บางรายการล่าช้าเกินกว่า 90 วันนับจากวันที่ Vendor ออก Patch เนื่องจากต้องรอ Change Window และทดสอบกับ Core Banking ก่อน	ปานกลาง-สูง

ส่วนที่ 3 — แผน IT เหตุการณ์สำคัญ และผลการตรวจสอบในอดีต

3.1 แผนกลยุทธ์ IT 3 ปี (พ.ศ. 2566 — 2568)

ธนาคารได้อนุมัติแผนกลยุทธ์ IT สำหรับปี 2566-2568 มูลค่ารวม 890 ล้านบาท โดยมีโครงการสำคัญดังนี้

โครงการ	งบประมาณ	ปีเริ่ม-สิ้นสุด	สถานะ	ความเสี่ยงโครงการ
Core Banking Upgrade (T24 R23)	280 ล้านบาท	2566-2567	ล่าช้า 8 เดือน	งบบานปลาย, Vendor ขอเพิ่มค่าใช้จ่าย 35 ล้านบาท
New Mobile Banking Platform (v3.0)	120 ล้านบาท	2566-2566	เสร็จสิ้น (มีนาคม 2567)	Post-launch พบ Bug ที่กระทบ UX 12 รายการ
Cybersecurity Enhancement Program	95 ล้านบาท	2566-2568	กำลังดำเนินการ	SOC ภายนอกที่ว่าจ้างยังอยู่ระหว่าง Onboarding
Data Center Modernization	220 ล้านบาท	2567-2568	ยังไม่เริ่ม	รอ Board อนุมัติรอบถัดไป
PDPA Compliance Program	45 ล้านบาท	2566-2567	ล่าช้า 5 เดือน	Legal และ IT ยังโต้แย้งขอบเขตความรับผิดชอบ

3.2 เหตุการณ์และอุบัติการณ์ด้าน IT ที่สำคัญ (พ.ศ. 2563-2568)

หมายเหตุ: ตารางนี้สรุปเหตุการณ์สำคัญที่ใช้ประกอบการวิเคราะห์ในกรณีศึกษา และได้ขยายข้อมูลต่อเนื่องถึงปี *2568* เพื่อให้เห็นพัฒนาการของความเสี่ยงและคุณภาพการควบคุมอย่างสมจริงมากขึ้น

วันที่	เหตุการณ์	สาเหตุที่บันทึก	ผลกระทบ / การแก้ไข
ก.พ. 2564	ระบบ Internet Banking ล่ม 4 ชั่วโมง	Emergency Change ที่ไม่ผ่าน UAT ถูก Deploy สู่ Production โดย Developer หัวหน้าทีม	ลูกค้าได้รับผลกระทบประมาณ 180,000 ราย ธปท. เรียกชี้แจง และยังไม่มีการปรับปรุง SoD อย่างเป็นทางการ
ส.ค. 2564	ข้อมูลรายงาน ธปท. ไม่ตรงกับ Core Banking	กระบวนการ Manual Batch ระหว่าง CLS และ T24 ล้มเหลวโดยไม่มีการแจ้งเตือน	ธนาคารต้องส่งรายงานแก้ไขต่อ ธปท. ล่าช้า 3 วันทำการ และถูกบันทึกเป็น Regulatory Finding
มี.ค. 2565	แรนซัมแวร์โจมตีระบบ Email Server (ไม่ใช่ Core Banking)	Phishing Email ที่พนักงานเปิดอ่านทำให้รหัสผ่านของ Admin Account ถูก Compromise	Email Server หยุดทำงาน 2 วัน ไม่มีข้อมูลลูกค้าถูกเข้ารหัส แต่พบว่า Backup ที่ Restore กลับมามีข้อมูลย้อนหลังเพียง 6 เดือนก่อนหน้า
ต.ค. 2565	KSB Go Mobile App ล่ม 2 ชั่วโมงระหว่างช่วง Peak (วันศุกร์สิ้นเดือน)	AWS Lambda Function หมด Concurrency Limit โดยทีมไม่ได้ตั้ง Alert Threshold ไว้	ธุรกรรมค้างคา 14,000 รายการ ลูกค้าร้องเรียน ธปท. 28 ราย
เม.ย. 2566	KSB Go Mobile App ล่มอีกครั้ง 6 ชั่วโมง	Database Connection Pool ของ API Gateway เต็ม เนื่องจาก Feature ใหม่ที่ Release ก่อนหน้าไม่ได้ผ่าน Load Testing อย่างครบถ้วน	ธุรกรรมค้างคา 42,000 รายการ ลูกค้าร้องเรียน ธปท. 19 ราย และ CEO แสดงความไม่พอใจต่อ CIO อย่างเป็นทางการ
ก.ค. 2567	แผนทดสอบ DR สำหรับ KSB Go และ API Gateway ถูกเลื่อนก่อนวันทดสอบ 2 วัน	Runbook การกู้คืนยังไม่ครบถ้วน ยังระบุ Dependency ระหว่างระบบบน AWS กับบริการยืนยันตัวตนภายในองค์กรไม่ครบ และ Business Owner ยังไม่ลงนามรับรองขั้นตอน	การทดสอบทำได้เพียง Tabletop Exercise แบบจำกัดขอบเขต Audit Committee ขอให้ CIO รายงานสถานะ DR Readiness ฉบับใหม่ภายใน 30 วัน

พ.ย. 2568	พบการใช้สิทธิ์ระดับสูงบน Production เพื่อแก้ปัญหา Regulatory Reporting แบบเร่งด่วน	Senior Developer ใช้ Script แก้ไขข้อมูลและตรวจสอบตารางบนฐานข้อมูล Production ภายใต้การอนุญาตด้วยวาจา โดยไม่มี Ticket ที่อนุมัติครบ และไม่มี Post-Implementation Review ตามกระบวนการ	ไม่พบความเสียหายของข้อมูลจากการตรวจสอบเบื้องต้น แต่ Audit Trail ไม่สมบูรณ์ Internal Audit เปิดประเด็นติดตามเรื่อง Privileged Access, Emergency Change และ Management Override

3.3 ผลการตรวจสอบจากผู้สอบบัญชีภายนอก (External Auditor Findings)

ในรอบการตรวจสอบประจำปี 2564 และ 2565 บริษัทสอบบัญชีภายนอก (Big 4 แห่งหนึ่ง) ได้ระบุข้อบกพร่องด้าน ITGC ไว้ในรายงาน Management Letter ดังนี้

รหัส Finding	ปีที่พบ	รายละเอียด	ระดับ	สถานะการแก้ไข (ณ ปัจจุบัน)
ITGC-01	2564, 2565	Shared Privileged Account บน Production Database ของ T24: Admin Account ชื่อ 'db_admin_prod' ใช้ร่วมกันโดย 4 คน ไม่สามารถระบุผู้กระทำรายการได้ (Non-repudiation failure)	High	ยังเปิดอยู่ — ทีม IT อ้างว่า T24 Version ปัจจุบันไม่รองรับ Individual Privileged Account ต้อง Upgrade ก่อน
ITGC-02	2564	Segregation of Duties ด้าน Change Management: Developer 3 รายมีสิทธิ์ Access ทั้ง Development และ Production Environment พร้อมกัน	High	แก้ไขบางส่วน — ตัดสิทธิ์ Developer 2 ราย แต่ Developer อาวุโส 1 รายยังคงมีสิทธิ์ทั้งสอง Environment เนื่องจาก Management อนุมัติ Business Exception
ITGC-03	2565	Backup Restoration Test: ไม่มีหลักฐานการทดสอบการ Restore ข้อมูลสำรองในรอบปีที่ผ่านมา ไม่สามารถยืนยันความสมบูรณ์ของ Backup ได้	High	ยังเปิดอยู่ — ทีม IT ระบุในแผนว่าจะทดสอบใน Q2/2567 แต่ยังไม่มีหลักฐาน
ITGC-04	2565	User Access Review: ไม่มีการทำ Periodic Access	High	แก้ไขบางส่วน — Deactivate Account ของ Terminated

		Recertification ตามรอบที่กำหนด (กำหนดทุก 6 เดือน แต่ครั้งล่าสุดเกิน 14 เดือนแล้ว) พบ Terminated Employee 12 รายที่ Account ยังใช้งานได้		Employee แล้ว แต่กระบวนการ Recertification ยังไม่ได้ปรับปรุงให้เป็น Automated
ITGC-05	2565	Emergency Change Abuse: สัดส่วน Emergency Change สูงผิดปกติ (32% ในปี 2565) โดยไม่มีการ Post-Implementation Review ครบถ้วน บาง Change ไม่มี Rollback Plan	Medium-High	ยังเปิดอยู่ — CIO รับทราบ แต่ระบุว่าเกิดจากความกดดันด้าน Business ซึ่งอยู่นอกเหนืออำนาจของฝ่าย IT

ข้อสอบปลายภาค

เลือกตอบ 5 ข้อจาก 6 ข้อ | แต่ละข้อ 20 คะแนน (ข้อย่อยละ 6-7 คะแนน) | รวม 100 คะแนน

บริบทสำคัญสำหรับการสอบ

ณ วันที่จัดทำข้อสอบนี้ ธนาคารเกษมทรัพย์กำลังเตรียมรับการตรวจสอบจากผู้สอบบัญชีภายนอกรอบปี 2566 ขณะเดียวกัน Audit Committee ได้ติดตาม incident ที่ต่อเนื่องถึงปี 2568 และกังวลว่าการควบคุมบางด้านอาจยังไม่ยั่งยืน

ข้อที่ 1: มุมมอง Internal Auditor - Assurance Engagement และการกำหนดขอบเขตงานตรวจสอบ

ท่านได้รับมอบหมายให้เป็น IT Auditor ของธนาคารเกษมทรัพย์ รับผิดชอบการตรวจสอบ IT General Controls ประจำปี 2566 ในฐานะส่วนหนึ่งของ Internal Audit Function ที่รายงานต่อ Audit Committee โดยตรง ฝ่ายบริหารขอให้ท่านเน้นเฉพาะระบบ Mobile Banking เนื่องจากเป็นระบบที่เกิดเหตุหยุดชะงักบ่อยครั้ง แต่ข้อมูลในกรณีศึกษายังสะท้อนปัญหาควบคุมที่เชื่อมโยงกับ Core Systems, Backup/DR, และ Privileged Access อย่างต่อเนื่องถึงปี 2568

หมายเหตุ: ไม่มีข้อมูลเพิ่มเติมนอกจากที่ระบุในกรณีศึกษา การตอบโดยอ้างว่า 'ต้องสอบถามข้อมูลเพิ่มเติม' โดยไม่ระบุเหตุผลเชิงวิชาชีพและผลต่อข้อสรุป จะไม่ได้รับคะแนน

ก) จากโครงสร้างองค์กรด้าน IT และประวัติ incident ของธนาคารเกษมทรัพย์ ท่านในฐานะ Internal Auditor ควรระบุประเด็นใดก่อนเป็นอันดับแรกในการวางแผนงานตรวจสอบ และเพราะเหตุใด จงอธิบายโดยเชื่อมโยงกับ control environment, governance oversight และความเสี่ยงที่อาจทำให้ผลการทดสอบควบคุมตีความคลาดเคลื่อน

ข) ฝ่ายบริหารร้องขอให้ท่านจำกัดขอบเขตงานตรวจสอบไว้เฉพาะ KSB Go Mobile Banking โดยให้เหตุผลว่าเป็นระบบที่ ธปท. ให้ความสนใจมากที่สุด ในฐานะ Internal Auditor ท่านจะยอมรับหรือท้าทายคำขอนี้อย่างไร จงอธิบาย reasoning ของท่านโดยคำนึงถึง independence, risk-based scoping และข้อเท็จจริงที่ incident หลายรายการเกิดจาก control weakness ที่อาจไม่ได้จำกัดอยู่เพียงระบบ front-end

ค) ระหว่างการตรวจสอบ ท่านพบว่า Finding ITGC-02 เรื่อง Segregation of Duties ของ Developer ยังเปิดอยู่จากปี 2564 และเหตุการณ์ในเดือนพฤศจิกายน 2568 สะท้อนว่ามีการใช้สิทธิ์ระดับสูงบน Production ภายใต้การอนุญาตด้วยวาจาอีกครั้ง ท่านจะสรุปและ escalate ประเด็นนี้ต่อ Audit Committee อย่างไร Management Exception เดิมควรยังถือว่า acceptable อยู่หรือไม่ และเพราะเหตุใด

ข้อที่ 2: มุมมอง IT Auditor - Risk Assessment, Audit Prioritization และ Professional Judgment

ท่านเป็น IT Auditor ที่ต้องประเมินความเสี่ยงเพื่อจัดทำแผนตรวจสอบเชิงลึกสำหรับธนาคารเกษมทรัพย์ โดยมีข้อจำกัดด้านเวลาและทรัพยากร กรณีศึกษาสะท้อนทั้งปัญหา Access Control, Change Management, Backup/DR, Application Interface, Patch Management และ Governance ซึ่งบางประเด็นเชื่อมโยงถึงเหตุการณ์ปี 2567-2568

คำเตือน: การจัดทุกความเสี่ยงว่า 'สำคัญเท่ากัน' หรือสรุปแบบกว้างโดยไม่อธิบายเกณฑ์การจัดลำดับ จะไม่ได้รับคะแนน

ก) หากท่านต้องเลือกประเด็นตรวจสอบเชิงลึกเพียง 3 เรื่องจากกรณีศึกษาทั้งหมดสำหรับรอบงานนี้ ท่านจะเลือกเรื่องใดบ้าง และเพราะเหตุใด จงอธิบายเกณฑ์ที่ใช้จัดลำดับ เช่น ผลกระทบต่อธุรกิจ ความเสี่ยงด้านกำกับดูแล ความน่าเชื่อถือของข้อมูล ความต่อเนื่องของเหตุการณ์ และความเป็นไปได้ที่จะเกิด management override

ข) สมมติว่าฝ่ายบริหารโต้แย้งว่า Shared Privileged Account, Backup Restoration Test และ Emergency Change Abuse ล้วนเป็นเรื่องที่ทราบอยู่แล้วและอยู่ในแผนแก้ไข จึงไม่ควรใช้ทรัพยากร audit มากเกินไป ในฐานะ IT Auditor ท่านจะตอบอย่างไร และจะประเมินอย่างไรว่าแผนแก้ไขของฝ่ายบริหารลด audit risk ลงได้จริงหรือยัง

ค) ระหว่างการ walkthrough ท่านพบโดยบังเอิญว่า Developer คนหนึ่งสามารถ query ข้อมูลลูกค้าจาก Production Database ได้โดยอ้างการอนุญาตด้วยวาจา แม้ประเด็นนี้จะไม่ได้อยู่ในขอบเขตหลักของงานในตอนแรก ท่านควรจัดการอย่างไรในฐานะ IT Auditor จงอธิบายทั้งมุมมองเรื่อง scope expansion, documentation ใน working paper และเหตุผลว่าควรเชื่อมโยงกับ finding เดิมหรือเปิดประเด็นใหม่

ข้อที่ 3: มุมมอง External Auditor - การประเมิน ITGC ต่อความน่าเชื่อถือของ Financial Statement Audit

ท่านเป็น IT Audit Senior ของบริษัทสอบบัญชีภายนอกที่รับผิดชอบการตรวจสอบ IT General Controls ของธนาคารเกษมทรัพย์ในรอบปี 2566 งานของท่านคือประเมินว่า IT Controls สนับสนุนความน่าเชื่อถือของข้อมูลทางการเงินเพียงใด โดยพิจารณาทั้ง findings เดิม เหตุการณ์ที่เกิดซ้ำ และความสมบูรณ์ของหลักฐานการแก้ไข

คำเตือน*: ท่านไม่สามารถจัดทุก finding เป็น material weakness* ได้ทั้งหมด การจัดลำดับและการเชื่อมโยงกับความเสี่ยงด้านงบการเงินคือสิ่งที่วัดความเข้าใจ

ก) จาก findings ที่ยังเปิดอยู่ทั้งหมด และข้อมูล incident ที่ต่อเนื่องถึงปี 2568 ท่านจะประเมินอย่างไรว่า finding ใดมีนัยสำคัญต่อ Financial Statement Audit มากที่สุด จงจัดลำดับความสำคัญของ ITGC-01, ITGC-03, ITGC-04 และประเด็นการใช้สิทธิ์ Production โดยไม่ผ่านเอกสารอนุมัติ พร้อมอธิบายความเชื่อมโยงกับ completeness, accuracy, authorization และ audit trail ของข้อมูลทางการเงิน

ข) ITGC-03 เรื่อง Backup Restoration Test ถูกพบครั้งแรกในปี 2565 และยังคงไม่มีหลักฐานเพียงพอจนต่อเนื่องไปถึงเหตุการณ์ที่แผน DR ปี 2567 ถูกเลื่อน Management ระบุว่ากำลังดำเนินการปรับปรุงอยู่ ในฐานะ External Auditor ท่านจะให้น้ำหนักกับ management response นี้อย่างไร และจะนำเสนอ repeat finding นี้ใน management letter อย่างไร

ค) ท่านได้เขียนร่าง finding สำหรับ ITGC-01 เรื่อง Shared Privileged Account และ Management ขอให้ลด severity โดยอ้างว่ามี log และมีการ review ทุกสัปดาห์ แต่หลักฐานการ review มีเพียงบางครั้งและไม่สม่ำเสมอ จงอธิบายว่าท่านจะสรุปเรื่อง sufficiency of evidence อย่างไร และเขียนโครงร่าง finding statement ฉบับสุดท้ายในรูปแบบที่ใช้ได้จริงใน management letter

ข้อที่ 4: มุมมอง IT Auditor - ประเมินความเสี่ยงของ SDLC Approach และการกำกับการเปลี่ยนแปลงระบบ

ท่านเป็น IT Auditor ของธนาคารเกษมทรัพย์ที่รับผิดชอบตรวจสอบโครงการ Core Banking Upgrade (T24 R23) ฝ่าย IT ตัดสินใจใช้แนวทาง Agile สำหรับบางส่วนของโครงการเพื่อเร่งการส่งมอบ ขณะที่องค์กรมีประวัติ emergency change สูงผิดปกติและมี incident จากการทดสอบไม่ครบถ้วน

คำเตือน*: การตอบว่า Agile ดีหรือไม่ดีโดยทั่วไปโดยไม่เชื่อมกับบริบทของธนาคารและข้อจำกัดด้านการควบคุม จะไม่ได้รับคะแนน*

ก) ฝ่าย IT อ้างว่าการใช้ Agile จะช่วยลดความล่าช้าของโครงการซึ่งเลยกำหนดมาแล้ว 8 เดือน และยังสามารถรักษา regulatory compliance ได้ ในฐานะ IT Auditor ท่านจะประเมิน claim นี้อย่างไร จงระบุความเสี่ยงด้าน audit evidence, formal sign-off, traceability และ testing discipline อย่างน้อย 3 ประการ พร้อมอธิบายว่าความเสี่ยงเหล่านี้เชื่อมโยงกับกรณีศึกษาที่มีอยู่เดิมอย่างไร

ข) จากข้อเท็จจริงที่ Emergency Change อยู่ที่ 34% ในปี 2566, Mobile Banking เคยล่มจากการทดสอบไม่ครบถ้วน, และในปี 2568 ยังพบการใช้ script บน Production ภายใต้การอนุญาตด้วยวาจา ท่านจะออกแบบ audit test อย่างไรเพื่อตรวจสอบว่า SDLC และ Change Management ที่ใช้อยู่มีประสิทธิผลเพียงพอ จงระบุ (1) control objectives (2) audit procedures และ (3) evidence ที่จะใช้สรุปผล

ค) ฝ่าย IT นำเสนอแผน Hybrid approach โดยใช้ Waterfall สำหรับ core module และ Agile สำหรับ interface และ reporting module ท่านจะประเมินแนวทางนี้อย่างไร ความเสี่ยงคงเหลืออะไรบ้าง และข้อสังเกตของท่านควรถูกบันทึกใน working paper อย่างไร โดยคำนึงถึงข้อเท็จจริงที่ ITGC-01, ITGC-03 และ DR readiness ยังไม่เข้มแข็ง

ข้อที่ 5: มุมมอง IT Auditor - Business Application Controls ของ TEMENOS T24 Core Banking

ท่านเป็น IT Auditor ที่ได้รับมอบหมายให้ตรวจสอบ Business Application Controls ของ TEMENOS T24 Core Banking ซึ่งประมวลผลธุรกรรมประมาณ 240,000 รายการต่อวัน ครอบคลุมลูกค้า 1.4 ล้านราย ข้อมูลในกรณีศึกษาสะท้อนทั้งประเด็น Shared Admin Account, Manual Batch Interface, Version Gap และความเสี่ยงจากการควบคุมการเข้าถึง Production

คำเตือน*: การตอบเพียงว่า Shared Admin Account เป็น Access Control โดยไม่วิเคราะห์ผลต่อ Application Control และความน่าเชื่อถือของข้อมูล จะได้คะแนนไม่ครบ*

ก) จงวิเคราะห์ว่าประเด็นสำคัญที่พบใน T24 และระบบที่เชื่อมต่อเกี่ยวข้องกับ Input Controls, Processing Controls หรือ Output Controls อย่างไร พร้อมอธิบายว่าแต่ละประเด็นกระทบต่อความน่าเชื่อถือของข้อมูลในงบการเงินหรือรายงานกำกับดูแลอย่างไร

ข) เหตุการณ์เดือนสิงหาคม 2564 ระบุว่า Manual Batch Interface ระหว่าง Core Lending System (CLS) กับ T24 ล้มเหลวโดยไม่มีการแจ้งเตือน จงออกแบบ control testing procedure สำหรับตรวจสอบ interface controls และ completeness controls โดยระบุ (1) test objectives (2) sampling approach ที่เหมาะสม (3) expected evidence และ (4) หลักเกณฑ์ที่ท่านจะใช้ conclude ผลการทดสอบ

ค) ระหว่าง walkthrough ท่านพบว่า T24 Version ปัจจุบันเก่ากว่า latest version อยู่ 3 major release และฝ่าย IT ระบุว่าต้องรอ upgrade ก่อนจึงจะแก้ Shared Admin Account ได้ ในฐานะ IT Auditor ท่านจะประเมินข้ออ้างนี้อย่างไร จงอธิบายทั้งผลกระทบของ version gap ต่อ application controls, compensating controls ที่ควรมีระหว่างรอ upgrade และแนวทางการสรุป finding อย่างมืออาชีพ

ข้อที่ 6: มุมมอง IT Auditor - ประเมิน IT Governance และ IT Service Management โดยอ้างอิง COBIT และ ITIL

ท่านเป็น IT Auditor ที่ได้รับมอบหมายให้ประเมินความเพียงพอของ IT Governance ของธนาคารเกษมทรัพย์เพื่อรายงานต่อ Audit Committee จากกรณีศึกษาพบว่า CIO รายงานต่อ CFO, IT Security ไม่ได้มีสายรายงานอิสระ, ไม่มีการประเมิน DR readiness อย่างอิสระ, และ emergency change ถูกใช้จนกลายเป็นพฤติกรรมปกติขององค์กร

คำเตือน*: การอธิบาย COBIT หรือ ITIL แบบทฤษฎีล้วนโดยไม่ map กับข้อเท็จจริงในกรณีศึกษา จะไม่ได้รับคะแนน*

ก) โดยอ้างอิง COBIT จงประเมินช่องว่างด้าน IT Governance อย่างน้อย 3 ประการจากกรณีศึกษา และ map แต่ละช่องว่างกับ governance objective หรือ management objective ที่เกี่ยวข้อง พร้อมอธิบายว่าช่องว่างเหล่านี้ส่งผลต่อประสิทธิผลของการควบคุมภายในและการกำกับดูแลของธนาคารอย่างไร

ข) ปัญหา Emergency Change, incident ที่เกิดซ้ำ, การทดสอบ DR ที่เลื่อนในปี 2567 และการใช้สิทธิ์ Production ภายใต้การอนุญาตด้วยวาจาในปี 2568 สะท้อนจุดอ่อนของ IT Service Management จงอธิบายว่า ITIL practices ใดที่เกี่ยวข้องโดยตรงกับปัญหาเหล่านี้ และในฐานะ IT Auditor ท่านจะใช้ข้อเท็จจริงใดประเมินว่าองค์กรนำ practices เหล่านั้นไปใช้ได้จริงหรือไม่

ค) หากท่านต้องสรุปต่อ Audit Committee ว่าธนาคารควรเริ่มปรับปรุง IT Governance จากจุดใดก่อน จงเสนอ quick wins 3 รายการที่ทำได้ภายใน 90 วันโดยไม่ต้องรอการลงทุนขนาดใหญ่ และ long-term structural changes 2 รายการที่ควรเสนอให้ Board พิจารณา พร้อมเหตุผลจากกรณีศึกษาที่สนับสนุนข้อเสนอของท่าน

— จบแบบทดสอบ —